

A. Introduction

1. **Title:** Cyber Security — System Security Management
2. **Number:** RRC-CIP-007-1
3. **Purpose:** To manage system security by specifying select technical, operational, and procedural requirements in support of protecting BES Cyber Systems (BCS) against compromise that could lead to misoperation or instability in the Bulk Electric System (BES).
4. **Applicability:**
 - 4.1. **Functional Entities:** For the purpose of the requirements contained herein, the following list of functional entities will be collectively referred to as “Responsible Entities.”
 - 4.1.1. **Balancing Authority**
 - 4.1.2. **Distribution Provider:** that owns one or more of the following Facilities, systems, and equipment for the protection or restoration of the BES:
 - 4.1.2.1. Each underfrequency load shedding (UFLS) or undervoltage loadshedding (UVLS) system that:
 - 4.1.2.1.1. is part of a Load shedding program that is subject to one or more requirements in an Railbelt Reliability Council Standard; and
 - 4.1.2.1.2. performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation, that the loss, compromise, or misuse could have an adverse impact on the reliable operation of the BES.
 - 4.1.2.2. Each Remedial Action Scheme (RAS) where the RAS is subject to one or more requirements in an Railbelt Reliability Council Standard.
 - 4.1.2.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in an Railbelt Reliability Council Standard.
 - 4.1.2.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.
 - 4.1.3. Generator Operator
 - 4.1.4. Generator Owner
 - 4.1.5. Transmission Operator
 - 4.1.6. Transmission Owner
 - 4.2. **Facilities:** For the purpose of the requirements contained herein, the following Facilities, systems, and equipment owned by each Responsible Entity in 4.1 above are those to which these requirements are applicable. For requirements in this standard where a specific type of Facilities, system, or equipment or subset of Facilities, systems, and equipment are applicable, these are specified explicitly.
 - 4.2.1. **Distribution Provider:** One or more of the following Facilities, systems and equipment

owned by the Distribution Provider for the protection or restoration of the BES:

4.2.1.1. Each UFLS or UVLS System that:

- 4.2.1.1.1.** is part of a Load shedding program that is subject to one or more requirements in an Railbelt Reliability Council Standard; and
- 4.2.1.1.2.** performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation, that the loss, compromise, or misuse could have an adverse impact on the reliable operation of the BES.

4.2.1.2. Each RAS where the RAS is subject to one or more requirements in an Railbelt Reliability Council Standard.

4.2.1.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in an Railbelt Reliability Council Standard.

4.2.1.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.

4.2.2. Responsible Entities listed in 4.1 other than Distribution Providers:

All BES Facilities.

4.2.3. Exemptions: The following are exempt from Standard **RRC-CIP-007-1**:

- 4.2.3.1.** Cyber Systems at Facilities regulated by the Canadian Nuclear Safety Commission.
- 4.2.3.2.** Cyber Assets associated with communication networks and data communication links between discrete Electronic Security Perimeters (ESP).
- 4.2.3.3.** Cyber Systems, associated with communication networks and data communication links, between Cyber Systems, providing confidentiality and integrity of an ESP that extends to one or more geographic locations.
- 4.2.3.4.** The systems, structures, and components that are regulated by the Nuclear Regulatory Commission under a cyber security plan pursuant to 10 C.F.R. Section 73.54.
- 4.2.3.5.** For Distribution Providers, the systems and equipment that are not included in section 4.2.1 above.
- 4.2.3.6.** Responsible Entities that identify that they have no BES Cyber Systems categorized as high impact or medium impact according to the RRC-CIP-002-1 identification and categorization processes.

4.2.3.7. Cyber Systems, associated with communication networks and data communication links, between the Cyber Systems providing confidentiality and integrity of an ESP.

4.2.3.8. Responsible Entities that identify that they have no BES Cyber Systems (BES) categorized as high impact or medium impact according to the CIP-002 identification and categorization processes.

4.3. “Applicable Systems”: Each table has an “Applicable Systems” column to define the scope of systems to which a specific requirement part applies.

5. Effective Dates: Shall become effective on the first day of the first calendar quarter that is twenty-four (24) months following adoption by the Approving Authority.

B. Requirements and Measures

- R1.** Each Responsible Entity shall implement one or more documented process(es) that collectively include each of the applicable requirement parts in RRC-CIP-007-1 *Table R1 – System Hardening*. [Violation Risk Factor: Medium]
- M1.** Evidence must include the documented processes that collectively include each of the applicable requirement parts in RRC-CIP-007-1 *Table R1 – System Hardening* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-007-1 Table R1 – System Hardening			
Part	Applicable Systems	Requirements	Measures
1.1	High Impact BES Cyber Systems (BCS) and their associated: - Electronic Access Control and Monitoring Systems (EACMS); - Physical Access Control Systems (PACS); and - Protected Cyber Asset (PCA) Medium impact BCS with ERC and their associated: - EACMS; - PACS; and - PCA SCI supporting an Applicable System in this Part.	Disable or prevent unneeded routable protocol network accessibility on each Applicable System, per system capability.	Examples of evidence may include, but are not limited to: - Documentation of the need for all enabled network accessible logical ports or network accessible logical services, individually or by group. - Listings of the listening ports, individually or by group, from either configuration files or settings, command output (such as netstat), or network scans of open ports; - Configuration or settings of host-based firewalls or other device level mechanisms that disable or prevent unneeded network accessible logical ports or network accessible logical services; or - Identity or process based access policy or workload configuration demonstrating needed network accessibility.

RRC-CIP-007-1 Table R1 – System Hardening			
Part	Applicable Systems	Requirements	Measures
1.2	High Impact BCS and their associated: 1. PCA; and 2. Nonprogrammable communication components located inside both a PSP and an ESP. Medium Impact BCS at Control Centers and their associated: 1. PCA; and 2. Nonprogrammable communication components located inside both a PSP and an ESP. SCI supporting an Applicable System in this Part.	Protect against the use of unnecessary physical input/output ports used for network connectivity, console commands, or Removable Media.	An example of evidence may include, but is not limited to, documentation showing types of protection of physical input/output ports, either logically through system configuration or physically using a port lock or signage.
1.3	SCI supporting either: High impact BCS or their associated PCA. Medium impact BCS or their associated PCA.	Mitigate the risk of CPU or memory vulnerabilities by preventing the sharing of CPU resources and memory resources, excluding storage resources, between VCAs that are, or are associated with, a medium or high impact BCS, and VCAs that are not, or are not associated with, a medium or high impact BCS.	Examples of evidence may include, but are not limited to, documentation of the configuration or settings showing that the CPU and memory cannot be shared, such as: • Virtualization affinity rules; or • Hardware partitioning of physical Cyber Assets.

- R2.** Each Responsible Entity shall implement one or more documented process(es) that collectively include each of the applicable requirement parts in RRC-CIP-007-1 *Table R2 – Cyber Security Patch Management*. [Violation Risk Factor: Medium]
- M2.** Evidence must include each of the applicable documented processes that collectively include each of the applicable requirement parts in RRC-CIP-007-1 *Table R2 – Cyber Security Patch Management* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-007-1 Table R2 – Cyber Security Patch Management			
Part	Applicable Systems	Requirements	Measures
2.1	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part	A patch management process for tracking, evaluating, and installing cyber security patches for applicable Cyber Assets. The tracking portion shall include the identification of a source or sources that the Responsible Entity tracks for the release of cyber security patches for applicable Cyber Assets that are updateable and for which a patching source exists.	Examples of evidence may include, but are not limited to, documentation of a patch management process and documentation or lists of sources that are monitored.

RRC-CIP-007-1 Table R2 – Cyber Security Patch Management			
Part	Applicable Systems	Requirements	Measures
2.2	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	At least once every 70 calendar days, evaluate cyber security patches for applicability that have been released since the last evaluation from the source or sources identified in Part 2.1.	Examples of evidence may include, but are not limited to, an evaluation conducted by, referenced by, or on behalf of a Responsible Entity of cyber security patches released by the documented sources at least once every 70 calendar days

RRC-CIP-007-1 Table R2 – Cyber Security Patch Management			
Part	Applicable Systems	Requirements	Measures
2.3	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	For applicable patches identified in Part 2.2, within 35 calendar days of the evaluation completion, take one of the following actions: • Apply the applicable patches; or • Create a dated mitigation plan; or • Revise an existing mitigation plan. Mitigation plans shall include the Responsible Entity's planned actions to mitigate the vulnerabilities addressed by each security patch and a timeframe to complete these mitigations.	Examples of evidence may include, but are not limited to: • Records of the installation of the patch (e.g., change management logs, exports from automated patch management tools that provide installation date, verification of BES Cyber System Component software revision, or registry exports that show software has been installed); or • A dated plan showing when and how the vulnerability will be addressed, to include documentation of the actions to be taken by the Responsible Entity to mitigate the vulnerabilities addressed by the security patch and a timeframe for the completion of these mitigations.

RRC-CIP-007-1 Table R2 – Cyber Security Patch Management			
Part	Applicable Systems	Requirements	Measures
2.4	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	For each mitigation plan created or revised in Part 2.3, implement the plan within the timeframe specified in the plan, unless a revision to the plan or an extension to the timeframe specified in Part 2.3 is approved by the CIP Senior Manager or delegate.	An example of evidence may include, but is not limited to, records of implementation of mitigations, and any approval records for mitigation plan revisions or extensions.

- R3.** Each Responsible Entity shall implement one or more documented process(es) that collectively include each of the applicable requirement parts in RRC-CIP-007-1 Table R3 – Malicious Code Prevention. *[Violation Risk Factor: Medium]*
- M3.** Evidence must include each of the documented processes that collectively include each of the applicable requirement parts in RRC-CIP-007-1 Table R3 – Malicious Code Prevention and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-007-1 Table R3 – Malicious Code Prevention			
Part	Applicable Systems	Requirements	Measures
3.1	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Deploy method(s) to deter, detect, or prevent malicious code.	An example of evidence may include, but is not limited to, records of the Responsible Entity's performance of these processes (e.g., through traditional antivirus, system hardening, policies, etc.).

RRC-CIP-007-1 Table R3 – Malicious Code Prevention			
Part	Applicable Systems	Requirements	Measures
3.2	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Mitigate the threat of detected malicious code.	Examples of evidence may include, but are not limited to: • Records of response processes for malicious code detection • Records of the performance of these processes when malicious code is detected.
3.3	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	For those methods identified in Part 3.1 that use signatures or patterns, have a process for the update of the signatures or patterns. The process must address testing and installing the signatures or patterns.	An example of evidence may include, but is not limited to, documentation showing the process used for the update of signatures or patterns.

- R4.** Each Responsible Entity shall implement one or more documented process(es) that collectively include each of the applicable requirement parts in RRC-CIP-007-1 *Table R4 – Security Event Monitoring*. [Violation Risk Factor: Medium].
- M4.** Evidence must include each of the documented processes that collectively include each of the applicable requirement parts in RRC-CIP-007-1 *Table R4 – Security Event Monitoring* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-007-1 Table R4 – Security Event Monitoring			
Part	Applicable Systems	Requirements	Measures
4.1	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Log security events, per system capability, for identification of, and after-the-fact investigations of, Cyber Security Incidents that include, at a minimum, each of the following types of events: 4.1.1. Detected successful login attempts; 4.1.2. Detected failed access attempts and failed login attempts; 4.1.3. Detected malicious code.	Examples of evidence may include, but are not limited to, a paper or system generated listing of event types for which the Applicable System is capable of detecting and, for generated events, is configured to log. This listing must include the required types of events.

RRC-CIP-007-1 Table R4 – Security Event Monitoring			
Part	Applicable Systems	Requirements	Measures
4.2	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS with External Routable Connectivity and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Generate alerts for security events that the Responsible Entity determines necessitates an alert, that includes, as a minimum, each of the following types of events, per system capability: 4.2.1. Detected malicious code from Part 4.1; and 4.2.2. Detected failure of Part 4.1 event logging.	Examples of evidence may include, but are not limited to, paper or system-generated listing of security events that the Responsible Entity determined necessitate alerts, including paper or system generated list showing how alerts are configured.

RRC-CIP-007-1 Table R4 – Security Event Monitoring			
Part	Applicable Systems	Requirements	Measures
4.3	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS at Control Centers and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Retain applicable event logs identified in Part 4.1 for at least the last 90 consecutive calendar days except under CIP Exceptional Circumstances. Applicable Systems unable to retain event logs for at least 90 consecutive calendar days must take one of the following actions: • Implement alternative solutions to meet the requirement such as a centralized log management system; • Create a dated mitigation plan; or • Revise an existing mitigation plan. Mitigation plans shall include the Responsible Entity's planned actions to mitigate the applicable systems technical limitations, when the planned actions will be implemented, and the list of systems by manufacturer and model that cannot meet the requirement Mitigation plans must be submitted to the RRC at least once every 15 calendar months for approval	Examples of evidence may include, but are not limited to: • documentation of the event log retention process and paper or system generated reports showing log retention configuration set at 90 days or greater. • A dated mitigation plan showing when and how the log retention limitation will be addressed, to include documentation of the actions to be taken by the Responsible Entity to mitigate this limitation, timeframe for the completion of these mitigations, and list of systems that have this limitation.

RRC-CIP-007-1 Table R4 – Security Event Monitoring			
Part	Applicable Systems	Requirements	Measures
4.4	High Impact BCS and their associated: 1. EACMS; and 2. PCA SCI supporting an Applicable System in this Part.	Review a summarization or sampling of logged security events as determined by the Responsible Entity at intervals no greater than 35 calendar days to identify undetected Cyber Security Incidents.	Examples of evidence may include, but are not limited to, documentation describing the review, any findings from the review (if any), and dated documentation showing the review occurred.

- R5.** Each Responsible Entity shall implement one or more documented process(es) that collectively include each of the applicable requirement parts in RRC-CIP-007-1 *Table R5 – System Access Controls*. [Violation Risk Factor: Medium].
- M5.** Evidence must include each of the applicable documented processes that collectively include each of the applicable requirement parts in RRC-CIP-007-1 *Table 5 – System Access Controls* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-007-1 Table R5 – System Access Controls			
Part	Applicable Systems	Requirements	Measures
5.1	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS at Control Centers and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS with External Routable Connectivity and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Have a method(s) to enforce authentication of interactive user access, per system capability.	An example of evidence may include, but is not limited to, documentation describing how access is authenticated.

RRC-CIP-007-1 Table R5 – System Access Controls			
Part	Applicable Systems	Requirements	Measures
5.2	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Identify and inventory all known enabled default or other generic account types, either by system, by groups of systems, by location, or by system type(s).	Examples of evidence may include, but are not limited to, a listing of accounts by account types showing the enabled default or generic account types in use.
5.3	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS with External Routable Connectivity and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Identify individuals who have authorized access to shared accounts.	An example of evidence may include, but is not limited to, listing of shared accounts and the individuals who have authorized access to each shared account.

RRC-CIP-007-1 Table R5 – System Access Controls			
Part	Applicable Systems	Requirements	Measures
5.4	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Change known default passwords Applicable Systems unable to change known default passwords must take one of the following actions: • Create a dated mitigation plan; or • Revise an existing mitigation plan. Mitigation plans shall include the Responsible Entity's planned actions to: provide additional security controls both physical and cyber to mitigate this technical limitation, when the planned actions will be implemented, and the list of systems by manufacturer and model that cannot meet the requirement Mitigation plans must be submitted to the RRC at least once every 15 calendar months for approval	Examples of evidence may include, but are not limited to: • Records of a procedure that passwords are changed when new devices are in production; or • Documentation in system manuals or other vendor documents showing default vendor passwords were generated pseudo-randomly and are thereby unique to the device. • A dated mitigation plan showing when and how the default password change limitation will be addressed, to include documentation of the actions to be taken by the Responsible Entity to mitigate this issue, timeframe for the completion of these mitigations, and list of systems that have this limitation.

RRC-CIP-007-1 Table R5 – System Access Controls			
Part	Applicable Systems	Requirements	Measures
5.5	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	For password-only authentication for interactive user access, either technically or procedurally enforce the following password parameters: 5.5.1. Password length that is, at least, the lesser of eight characters or the maximum length supported by the Applicable Systems; and 5.5.2. Minimum password complexity that is the lesser of three or more different types of characters (e.g., uppercase alphabetic, lowercase alphabetic, numeric, non-alphanumeric) or the maximum complexity supported by the Applicable System.	Examples of evidence may include, but are not limited to: • System-generated reports or screen-shots of the system-enforced password parameters, including length and complexity; or • Attestations that include a reference to the documented procedures that were followed.
5.6	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS with External Routable Connectivity and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	For password-only authentication for interactive user access, either technically or procedurally enforce password changes or an obligation to change the password at least once every 15 calendar months, per system capability.	Examples of evidence may include, but are not limited to: • System-generated reports or screen-shots of the system-enforced periodicity of changing passwords; or • Attestations that include a reference to the documented procedures that were followed.

RRC-CIP-007-1 Table R5 – System Access Controls			
Part	Applicable Systems	Requirements	Measures
5.7	High Impact BCS and their associated: 1. EACMS; 2. PACS; and 3. PCA Medium Impact BCS at Control Centers and their associated: 1. EACMS; 2. PACS; and 3. PCA SCI supporting an Applicable System in this Part.	Limit the number of unsuccessful authentication attempts; or generate alerts after a threshold of unsuccessful authentication attempts.	Examples of evidence may include, but are not limited to: • Documentation of the account-lockout parameters; or • Rules in the alerting configuration showing how the system notified individuals after a determined number of unsuccessful login attempts.

C. Compliance

1. Compliance Monitoring Process

1.1. Compliance Enforcement Authority:

The RRC is the entity with the authority to monitor and enforce compliance with mandatory and enforceable Railbelt Reliability Council Standards.

1.2. Evidence Retention:

The following evidence retention periods identify the period of time an entity is required to retain specific evidence to demonstrate compliance. For instances where the evidence retention period specified below is shorter than the time since the last audit, the RRC may ask an entity to provide other evidence to show that it was compliant for the full time period since the last audit.

The Responsible Entity shall keep data or evidence to show compliance as identified below unless directed by the RRC to retain specific evidence for a longer period of time as part of an investigation:

- Each Responsible Entity shall retain evidence of each requirement in this standard for three calendar years.
- If a Responsible Entity is found non-compliant, it shall keep information related to the non-compliance until mitigation is complete and approved or the time specified above, whichever is longer.
- The RRC shall keep the last audit records and all requested and submitted subsequent audit records.

1.3. Compliance Monitoring and Enforcement Program:

Compliance Monitoring and Enforcement Program refers to the identification of the processes that will be used to evaluate data or information for the purpose of assessing performance or outcomes with the associated Railbelt Reliability Council Standards.

Table of Compliance Elements

R #	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-007-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R1.	Medium	The Responsible Entity did not document one or more process(es) that included the applicable items in CIP-007-7 Table R1. (Requirement R1)	The Responsible Entity had no methods to protect against unnecessary physical input/output ports used for network connectivity, console commands, or Removable Media. (R 1.2)	The Responsible Entity had one or more unneeded logical network accessible ports or network accessible services enabled. (R 1.1) OR The Responsible Entity has not prevented the sharing of the CPU and memory resources between VCAs that are, or are associated with, a Medium or High Impact BCS, and VCAs that are not, or are not associated with a Medium or High Impact BCS. (R 1.3)	The Responsible Entity neither implemented nor documented one or more process(es) that included the applicable items in RRC-CIP-007-1 Table R1. (Requirement R1)
R2.	Medium	The Responsible Entity did not evaluate the cyber security patches for applicability within 35 calendar days but less than 45 calendar days of the last evaluation for the source or sources identified. (R 2.2) OR The Responsible Entity did not apply the applicable cyber security patches, create a dated mitigation plan, or revise an	The Responsible Entity did not include any processes, including the identification of sources, for tracking or evaluating cyber security patches for Applicable Systems. (R 2.1) OR The Responsible Entity did not evaluate the cyber security patches for applicability within 45 calendar days but less than 55 calendar days of the last	The Responsible Entity did not include any processes for installing cyber security patches for Applicable Systems. (R 2.1) OR The Responsible Entity did not evaluate the cyber security patches for applicability 55 calendar days or greater of the last evaluation for the source or sources identified. (R 2.2) OR	The Responsible Entity did not implement or document one or more process(es) that included the applicable items in CIP-007-7 Table R2. (Requirement R2) OR The Responsible Entity did not include any processes for tracking, evaluating, or installing cyber security patches for applicable Cyber Assets. (R 2.1)

R #	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-007-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		existing mitigation plan within 70 calendar days but less than 80 calendar days of the evaluation completion. (R 2.3)	evaluation for the source or sources identified. (R 2.2) OR The Responsible Entity did not apply the applicable cyber security patches, create a dated mitigation plan, or revise an existing mitigation plan within 80 calendar days but less than 90 calendar days of the evaluation completion. (R 2.3)	The Responsible Entity did not apply the applicable cyber security patches, create a dated mitigation plan, or revise an existing mitigation plan within 90 calendar days or greater of the evaluation completion. (R 2.3)	OR The Responsible Entity did not obtain approval by the CIP Senior Manager or delegate. (R 2.4) OR The Responsible Entity did not implement the plan as created or revised within the timeframe specified in the plan. (R 2.4)
R3.	Medium	N/A	The Responsible Entity, where signatures or patterns are used, the Responsible Entity did not address testing the signatures or patterns. (R 3.3)	The Responsible Entity did not mitigate the threat of detected malicious code. (R 3.2) OR The Responsible Entity, where signatures or patterns are used, the Responsible Entity did not update malicious code protections. (R 3.3).	The Responsible Entity did not implement or document one or more process(es) that included the applicable items in RRC-CIP-007-1 Table R3. (Requirement R3). OR The Responsible Entity did not deploy method(s) to deter, detect, or prevent malicious code. (R 3.1)

R #	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-007-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R4.	Medium	The Responsible Entity missed one of 15 calendar day interval and completed the review within 25 calendar days of the prior review. (R 4.4)	The Responsible Entity missed two 15 calendar day intervals and completed the review within 25 calendar days of the prior review. (R 4.4)	The Responsible Entity did not generate alerts for all of the required types of security events described in 4.2.1 through 4.2.2. (R 4.2) OR The Responsible Entity did not retain applicable security event logs, create a dated mitigation plan, or revise an existing mitigation plan for at least the last 90 consecutive days. (R 4.3) OR The Responsible Entity missed four or more 15 calendar day intervals. (R 4.4)	The Responsible Entity did not implement or document one or more process(es) that included the applicable items in RRC-CIP-007-1 Table R4. (Requirement R4) OR The Responsible Entity, per system capability, did not detect and log all of the required types of events described in 4.1.1 through 4.1.3. (R 4.1)
R5.	Medium	The Responsible Entity did not technically or procedurally enforce password changes or an obligation to change the password within 15 calendar months but less than or equal to 17 calendar months of the last password change. (R 5.6)	The Responsible Entity did not technically or procedurally enforce password changes or an obligation to change the password within 17 calendar months but less than or equal to 19 calendar months of the last password change. (R 5.6)	The Responsible Entity did not include the identification or inventory of all known enabled default or other generic account types, either by system, by groups of systems, by location, or by system type(s). (R 5.2) OR The Responsible Entity did not include the identification of the individuals with authorized	The Responsible Entity did not implement or document one or more process(es) that included the applicable items in RRC-CIP-007-1 Table R5. (Requirement R5) OR The Responsible Entity does not have a method(s) to enforce authentication of interactive user access. (R 5.1)

R #	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-007-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
				access to shared accounts. (R 5.3) OR The Responsible Entity did not technically or procedurally enforce one of the two password parameters as described in 5.5.1 and 5.5.2. (R 5.5) OR The Responsible Entity process(es) for password-only authentication for interactive user access did not technically or procedurally enforce one of the two password parameters as described in 5.5.1 and 5.5.2. (R 5.5) OR The Responsible Entity did not technically or procedurally enforce password changes or an obligation to change the password within 19 calendar months but less than or equal to 21 calendar months of the last password change. (R 5.6)	OR The Responsible Entity does not have a method(s) to enforce authentication of interactive user access. (R 5.1) OR The Responsible Entity did not, per device capability, change known default passwords, create a dated mitigation plan, or revise an existing mitigation plan. (R 5.4) OR The Responsible Entity did not technically or procedurally enforce all of the password parameters described in 5.5.1 and 5.5.2. (R 5.5) OR The Responsible Entity did not technically or procedurally enforce password changes or an obligation to change the

R #	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-007-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
					password within 21 calendar months or greater of the last password change. (R 5.6) OR The Responsible Entity neither limited the number of unsuccessful authentication attempts nor generated alerts after a threshold of unsuccessful authentication attempts. (R 5.7)

D. Regional Variances

None.

E. Interpretations

None.

F. Associated Documents

None.

Version History

Version	Date	Action	Change Tracking

Glossary

Balancing Authority	The responsible entity that integrates resource plans ahead of time, maintains Demand and resource balance within a Balancing Authority Area, and supports Interconnection frequency in real time.
BES Cyber Asset (BCA)	A Cyber Asset that if rendered unavailable, degraded, or misused would, within 15 minutes of its required operation, misoperation, or non operation, adversely impact one or more Facilities, systems, or equipment, which, if destroyed, degraded, or otherwise rendered unavailable when needed, would affect the reliable operation of the Bulk Electric System. Redundancy of affected Facilities, systems, and equipment shall not be considered when determining adverse impact. Each BES Cyber Asset is included in one or more BES Cyber Systems.
BES Cyber System (BCS)	One or more BES Cyber Assets logically grouped by a responsible entity to perform one or more reliability tasks for a functional entity.
BES Cyber System Information (BCSI)	Information about the BES Cyber System that could be used to gain unauthorized access or pose a security threat to the BES Cyber System. BES Cyber System Information does not include individual pieces of information that by themselves do not pose a threat or could not be used to allow unauthorized access to BES Cyber Systems, such as, but not limited to, device names, individual IP addresses without context, ESP names, or policy statements. Examples of BES Cyber System Information may include, but are not limited to, security procedures or security information about BES Cyber Systems, Physical Access Control Systems, and Electronic Access Control or Monitoring Systems that is not publicly available and could be used to allow unauthorized access or unauthorized distribution; collections of network addresses; and network topology of the BES Cyber System.
Blackstart Resource	A generating unit(s) and its associated set of equipment which has the ability to be started without support from the System or is designed to remain energized without connection to the remainder of the System, with the ability to energize a bus, meeting the Transmission Operator's restoration plan needs for Real and Reactive Power capability, frequency and voltage control, and that has been included in the Transmission Operator's restoration plan.
Bulk Electric System (BES)	Unless modified by the lists shown below, all Transmission Elements operated at 100 kV or higher and Real Power and Reactive Power resources connected at 100 kV or higher. This does not include facilities used in the local distribution of electric energy. Inclusions: • I1 - Transformers with the primary terminal and at least one secondary terminal operated at 100 kV or higher unless excluded by application of Exclusion E1 or E3. • I2 – Generating resource(s) including the generator terminals through the high-side of the

	step-up transformer(s) connected at a voltage of 100 kV or above with: a) Gross individual nameplate rating greater than 20 MVA. Or, b) Gross plant/facility aggregate nameplate rating greater than 75 MVA. • I3 - Blackstart Resources identified in the Transmission Operator's restoration plan. • I4 - Dispersed power producing resources that aggregate to a total capacity greater than 75 MVA (gross nameplate rating), and that are connected through a system designed primarily for delivering such capacity to a common point of connection at a voltage of 100 kV or above. Thus, the facilities designated as BES are: a) The individual resources, and The system designed primarily for delivering capacity from the point where those resources aggregate to greater than 75 MVA to a common point of connection at a voltage of 100 kV or above. • I5 –Static or dynamic devices (excluding generators) dedicated to supplying or absorbing Reactive Power that are connected at 100 kV or higher, or through a dedicated transformer with a high-side voltage of 100 kV or higher, or through a transformer that is designated in Inclusion I1 unless excluded by application of Exclusion E4 Exclusions: • E1 - Radial systems: A group of contiguous transmission Elements that emanates from a single point of connection of 100 kV or higher and: a) Only serves Load. Or, b) Only includes generation resources, not identified in Inclusions I2, I3, or I4, with an aggregate capacity less than or equal to 75 MVA (gross nameplate rating). Or, c) Where the radial system serves Load and includes generation resources, not identified in Inclusions I2, I3 or I4, with an aggregate capacity of non- retail generation less than or equal to 75 MVA (gross nameplate rating). Note 1 – A normally open switching device between radial systems, as depicted on prints or one-line diagrams for example, does not affect this exclusion. Note 2 – The presence of a contiguous loop, operated at a voltage level of 50 kV or less, between configurations being considered as radial systems, does not affect this exclusion. • E2 - A generating unit or multiple generating units on the customer's side of the retail meter that serve all or part of the retail Load with electric energy if: (i) the net capacity provided to the BES does not exceed 75 MVA, and (ii) standby, back-up, and maintenance power services are provided to the generating unit or multiple generating units or to the retail Load by a Balancing Authority, or provided pursuant to a binding obligation with a Generator Owner or Generator Operator, or under terms approved by the applicable regulatory authority. • E3 - Local networks (LN): A group of contiguous transmission Elements operated at less than 300 kV that distribute power to Load rather than transfer bulk power across the interconnected system. LN's emanate from multiple points of connection at 100 kV or higher to improve the level of service to retail customers and not to accommodate bulk power transfer
--	--

Glossary

	across the interconnected system. The LN is characterized by all of the following: a) Limits on connected generation: The LN and its underlying Elements do not include generation resources identified in Inclusions I2, I3, or I4 and do not have an aggregate capacity of non-retail generation greater than 75 MVA (gross nameplate rating); b) Real Power flows only into the LN and the LN does not transfer energy originating outside the LN for delivery through the LN; and c) Not part of a Flowgate or transfer path: The LN does not contain any part of a permanent Flowgate in the Eastern Interconnection, a major transfer path within the Western Interconnection, or a comparable monitored Facility in the ERCOT or Quebec Interconnections, and is not a monitored Facility included in an Interconnection Reliability Operating Limit (IROL). • E4 – Reactive Power devices installed for the sole benefit of a retail customer(s). Note - Elements may be included or excluded on a case-by-case basis through b) the Rules of Procedure exception process.
CIP Exceptional Circumstance	A situation that involves or threatens to involve one or more of the following, or similar, conditions that impact safety or BES reliability: a risk of injury or death; a natural disaster; civil unrest; an imminent or existing hardware, software, or equipment failure; a Cyber Security Incident requiring emergency assistance; a response by emergency services; the enactment of a mutual assistance agreement; or an impediment of large scale workforce availability.
CIP Senior Manager	A single official with the authority to bind the registered entity to adhere to the requirements within the CIP Standards, CIP-002 through CIP-015.
Control Center	One or more facilities hosting operating personnel that monitor and control the Bulk Electric System (BES) in real-time to perform the reliability tasks, including their associated data centers, of: 1) a Reliability Coordinator, 2) a Balancing Authority, 3) a Transmission Operator for transmission Facilities at two or more locations, or 4) a Generator Operator for generation Facilities at two or more locations.
Cranking Path	A portion of the electric system that can be isolated and then energized to deliver electric power from a generation source to enable the startup of one or more other generating units.
Cyber Assets (CA)	Programmable electronic devices, including the hardware, software, and data in those devices.
Cyber Security Incident (CSI)	A malicious act or suspicious event that: • For a high or medium impact BES Cyber System, compromises or attempts to compromise (1) an Electronic Security Perimeter, (2) a Physical Security Perimeter, or (3) an Electronic Access Control or Monitoring System; or Disrupts or attempts to disrupt the operation of a BES Cyber System

Glossary

Distribution Provider	Provides and operates the “wires” between the transmission system and the end-use customer. For those end-use customers who are served at transmission voltages, the Transmission Owner also serves as the Distribution Provider. Thus, the Distribution Provider is not defined by a specific voltage, but rather as performing the distribution function at any voltage
Electronic Access Control or Monitoring Systems (EACMS)	Cyber Assets that perform electronic access control or electronic access monitoring of the Electronic Security Perimeter(s) or BES Cyber Systems. This includes Intermediate Systems.
Electronic Access Point (EAP)	A Cyber Asset interface on an Electronic Security Perimeter that allows routable communication between Cyber Assets outside an Electronic Security Perimeter and Cyber Assets inside an Electronic Security Perimeter.
Electronic Security Perimeter (ESP)	The logical border surrounding a network to which BES Cyber Systems are connected using a routable protocol.
Element	Any electrical device with terminals that may be connected to other electrical devices such as a generator, transformer, circuit breaker, bus section, or transmission line. An Element may be comprised of one or more components.
External Routable Connectivity (ERC)	Programmable electronic devices, excluding Shared Cyber Infrastructure, including the hardware, software, and data in those devices. Application containers are considered software of Virtual Cyber Assets (VCAs) or Cyber Assets. VCAs are not considered software or data of Cyber Assets.
Facility	A set of electrical equipment that operates as a single Bulk Electric System Element (e.g., a line, a generator, a shunt compensator, transformer, etc.)
Inoperable or Damaged	The loss of transmission elements preventing the facility from performing its intended function or physical destruction that prevents the facility from being restored to service through normal operating procedures
Interactive Remote Access (IRA)	User-initiated access by a person employing a remote access client or other remote access technology using a routable protocol. Remote access originates from a Cyber Asset that is not an Intermediate System and not located within any of the Responsible Entity’s Electronic Security Perimeter(s) or at a defined Electronic Access Point (EAP). Remote access may be initiated from: 1) Cyber Assets used or owned by the Responsible Entity, 2) Cyber Assets used or owned by employees, and 3) Cyber Assets
Physical Access Control Systems (PACS)	Cyber Assets that control, alert, or log access to the Physical Security Perimeter(s), exclusive of locally mounted hardware or devices at the Physical Security Perimeter such as motion sensors, electronic lock control mechanisms, and badge readers.

Glossary

Physical Security Perimeter (PSP)	The physical border surrounding locations in which BES Cyber Assets, BES Cyber Systems, or Electronic Access Control or Monitoring Systems reside, and for which access is controlled.
Protected Cyber Assets (PCA)	One or more Cyber Assets connected using a routable protocol within or on an Electronic Security Perimeter that is not part of the highest impact BES Cyber System within the same Electronic Security Perimeter. The impact rating of Protected Cyber Assets is equal to the highest rated BES Cyber System in the same ESP.
Real-time Assessment	An evaluation of system conditions using Real time data to assess existing (pre-Contingency) and potential (post Contingency) operating conditions. The assessment shall reflect applicable inputs including, but not limited to: load; generation output levels; known Protection System and Remedial Action Scheme status or degradation, functions, and limitations; Transmission outages; generator outages; Interchange; Facility Ratings; and identified phase angle and equipment limitations. (Realtime Assessment may be provided through internal systems or through third party services.)
Remedial Action Scheme (RAS)	The following do not individually constitute a RAS: a) Protection Systems installed for the purpose of detecting Faults on BES Elements and isolating the faulted Elements b) Schemes for automatic underfrequency load shedding (UFLS) and automatic undervoltage load shedding (UVLS) comprised of only distributed relays c) Out-of-step tripping and power swing blocking d) Automatic reclosing schemes e) Schemes applied on an Element for non-Fault conditions, such as, but not limited to, generator loss-of- field, transformer top-oil temperature, overvoltage, or overload to protect the Element against damage by removing it from service f) Controllers that switch or regulate one or more of the following: series or shunt reactive devices, flexible alternating current transmission system (FACTS) devices, phase-shifting transformers, variable-frequency transformers, or tap-changing transformers; and that are located at and monitor quantities solely at the same station as the Element being switched or regulated g) FACTS controllers that remotely switch static shunt reactive devices located at other stations to regulate the output of a single FACTS device h) Schemes or controllers that remotely switch shunt reactors and shunt capacitors for voltage regulation that would otherwise be manually switched i) Schemes that automatically de-energize a line for a non-Fault operation when one end of the line is open j) Schemes that provide anti-islanding protection (e.g., protect load from effects of being isolated with generation that may not be capable of maintaining acceptable frequency and voltage) k) Automatic sequences that proceed when manually initiated solely by a System Operator l) Modulation of HVdc or FACTS via supplementary controls, such as angle damping or frequency damping applied to damp local or inter-area oscillations

Glossary

	m) Sub-synchronous resonance (SSR) protection schemes that directly detect sub-synchronous quantities (e.g., currents or torsional oscillations) n) Generator controls such as, but not limited to, automatic generation control (AGC), generation excitation [e.g. automatic voltage regulation (AVR) and power system stabilizers(PSS)], fast valving, and speed governing
Reportable Cyber Security Incident	A Cyber Security Incident that compromised or disrupted: • A BES Cyber System that performs one or more reliability tasks of a functional entity; • An Electronic Security Perimeter of a high or medium impact BES CyberSystem; or • An Electronic Access Control or Monitoring System of a high or medium impact BES Cyber System
Shared Cyber Infrastructure (SCI)	One or more programmable electronic devices, including the software that shares the devices' resources, that: • Hosts one or more Virtual Cyber Assets (VCA) included in a BES Cyber Systems (BCS) or their associated Electronic Access Control or Monitoring Systems (EACMS) or Physical Access Control Systems (PACS); and hosts one or more VCAs that are not included in, or associated with, BCS of the same impact categorization; or • Provides storage resources required for system functionality of one or more Cyber Assets or VCAs included in a BCS or their associated EACMS or PACS; and also for one or more Cyber Assets or VCAs that are not included in, or associated with, BCS of the same impact categorization. SCI does not include the supported VCAs or Cyber Assets with which it shares its resources.
Transient Cyber Asset	A Cyber Asset that is: 1. capable of transmitting or transferring executable code, 2. not included in a BES Cyber System, 3. not a Protected Cyber Asset (PCA) associated with high or medium impact BES Cyber Systems, and 4. directly connected (e.g., using Ethernet, serial, Universal Serial Bus, or wireless including near field or Bluetooth communication) for 30 consecutive calendar days or less to a: • BES Cyber Asset, • network within an Electronic Security Perimeter (ESP) containing high or medium impact BES Cyber Systems, or • PCA associated with high or medium impact BES Cyber Systems. Examples of Transient Cyber Assets include, but are not limited to, Cyber Assets used for data transfer, vulnerability assessment, maintenance, or troubleshooting purposes.
Transmission	An interconnected group of lines and associated equipment for the movement or transfer of electric energy between points of supply and points at which it is transformed for delivery to customers or is delivered to other electric systems.

Glossary

Transmission Line	A system of structures, wires, insulators and associated hardware that carry electric energy from one point to another in an electric power system. Lines are operated at relatively high voltages varying from 69 kV up to 765 kV, and are capable of transmitting large quantities of electricity over long distances.
Transmission Planner	The entity that develops a long-term (generally one year and beyond) plan for the reliability (adequacy) of the interconnected bulk electric transmission systems within its portion of the Planning Authority area.
Transmission Operator	The entity responsible for the reliability of its “local” transmission system, and that operates or directs the operations of the transmission Facilities.
Transmission Owner	The entity that owns and maintains transmission Facilities.
Undervoltage Load Shedding Program	An automatic load shedding program, consisting of distributed relays and controls, used to mitigate undervoltage conditions impacting the Bulk Electric System (BES), leading to voltage instability, voltage collapse, or Cascading. Centrally controlled undervoltage-based load shedding is not included.
Virtual Cyber Asset	A logical instance of an operating system or firmware, currently executing on a virtual machine hosted on a BES Cyber Asset; Electronic Access Control or Monitoring System; Physical Access Control System; Protected Cyber Asset; or Shared Cyber Infrastructure (SCI). Virtual Cyber Assets (VCAs) do not include: • Logical instances that are being actively remediated in an environment that isolates routable connectivity from BES Cyber Systems; • Dormant file-based images that contain operating systems or firmware; or • SCI or Cyber Assets that host VCAs. • Application containers are considered software of VCAs or Cyber Assets